PRODUCT REQUIREMENTS DOCUMENT

MetabolicInt Phase 4 Foundations

Build-ready specification for the consolidated daily-summary dashboard, Indian three-tier lab panel presets, AI coach activation, and the account and data hygiene pack — with per-feature requirements, acceptance criteria, and the phase release gate.

MetabolicInt Engineering

Private deployment · metabolic-int-web.vercel.app

22 OCTOBER 2026 · VERSION 1.0 · APPROVED FOR BUILD

Table of Contents

1. Introduction and Document Control . . . 3

2. Background and Current State . . . 4

2.3 Current Data-Domain Inventory . . . 5

2.4 Known Issues and Phase 4 Preconditions . . . 5

3. Goals, Non-Goals and Success Metrics . . . 6

3.3 Success Metrics . . . 7

4. F1 - Consolidated Daily-Summary Dashboard (Digest v1) . . . 7

4.2 User Stories . . . 7

4.3 Functional Requirements . . . 8

4.4 Data and API Impact . . . 8

4.5 Acceptance Criteria . . . 9

4.6 Out of Scope . . . 9

5. F2 - Lab Entry Upgrade and Indian Diagnostic Panel Presets . . . 10

5.2 Proposed Tier Contents . . . 10

5.3 Functional Requirements . . . 10

5.4 Data and API Impact . . . 11

5.5 Acceptance Criteria . . . 11

5.6 Out of Scope . . . 12

6. F3 - AI Coach Activation . . . 12

6.2 Functional Requirements . . . 12

6.3 Degradation and Cost Posture . . . 13

6.4 Acceptance Criteria . . . 13

6.5 Out of Scope . . . 14

7. F4 - Account and Data Hygiene Pack . . . 14

7.2 Functional Requirements . . . 14

7.3 Acceptance Criteria . . . 15

7.4 Out of Scope . . . 15

8. Cross-Cutting Engineering Requirements . . . 16

8.3 Deployment and Verification Pipeline . . . 17

9. QA Plan and Release Gates 17

9.2 Release Gate Checklist 18

10. Milestones and Sequencing 18

11. Risks and Mitigations 19

12. Open Questions 19

Appendix A - Current API Inventory 20

Appendix B - Production Environment Policy 21

1. Introduction and Document Control

1.1 Purpose

This document is the formal product requirements specification for Phase 4 of MetabolicInt, the private, authentication-gated metabolic health tracker deployed at https://metabolic-int-web.vercel.app. It converts the Phase 4 planning session of 2026-10-22 into a build-ready brief: every feature carries a scope statement, numbered functional requirements, data and API implications, and testable acceptance criteria. The document is deliberately self-contained, because its primary consumer is a build session that will not have access to the deployment conversations that produced it. All decisions recorded here were agreed with the product owner during the Phase 3 deployment session and the next-phase brainstorm that followed it.

1.2 Audience and How to Use This Document

The audience is the engineer or AI build session that implements Phase 4, plus the product owner who verifies the result. A build session should treat chapters 4 through 7 as the feature work queue, chapter 8 as binding engineering constraints, and chapter 9 as the definition of done. Acceptance criteria are written in Given / When / Then form so they can be executed literally as manual or automated checks. If a requirement in this document conflicts with an earlier assumption, this document wins; if it conflicts with production safety (chapter 8), production safety wins and the conflict must be raised to the owner before implementation proceeds.

1.3 Document Control

The table below records the identity of this specification. The document is versioned as a whole; per-feature revision history is not maintained. Any change after approval should bump the version and note the reason in the phase worklog.

Field	Value
Product	MetabolicInt (web app, apps/web workspace)
Phase	Phase 4 - Foundations for intelligence
Document	Product Requirements Document, version 1.0
Date	22 October 2026
Status	Approved for build handoff
Owner	Product owner (family administrator)
Implementation	Single build session, milestone-gated per chapter 10
Predecessors	Phase 1-3 worklogs, docs/phase3-worklog.md
Baseline code	Git HEAD of the Phase 3 phase-gate commit

1.4 Conventions

Requirement identifiers follow the pattern FR-x.y, where x is the feature number (F1 = digest, F2 = lab panels, F3 = coach, F4 = hygiene) and y is the requirement number within that feature. The words MUST and SHOULD are used in the RFC 2119 sense: MUST items block release, SHOULD items may be traded off with the owner consent recorded in the worklog. Acceptance criteria use AC-x.y identifiers and reference the requirement they verify. Monetary and rate figures are defaults that the owner may tune; they are called out in chapter 12 as open questions where that applies.

2. Background and Current State

2.1 Product and Platform

MetabolicInt is a private web application used by a single household of six people to track metabolic health: glucose readings, meals and food combinations, custom foods, an Indian food database, medication schedules and logs, lab results, activity, sleep, blood pressure, and weight. The stack is a Next.js 15.5.19 App Router application with next-auth 4.24.14 credential authentication, Prisma 5.22 on Turso (libsql) as the datastore, and a Vercel deployment under the team vignan-guild in the project metabolic-int-web. The production URL is https://metabolic-int-web.vercel.app and every route is authentication-gated; the public probe suite expects a bare 401 from the export API and 200 only from marketing, login, and CSRF endpoints.

2.2 Phase History

Phase 1 produced the local application skeleton and the first tracking pages. Phase 2 expanded the feature surface to the current page inventory and scaffolded an AI coach page together with an OPENAI_API_KEY placeholder that was never activated. Phase 3 was the production pivot: the stray, prebuilt-artifact project was abandoned, the repository was relinked to the Git-integrated project metabolic-int-web, the environment store was audited under an add-only policy, a cloud-build production deployment shipped, and a four-URL public probe suite passed with the expected 200 / 200 / 200 pattern and a self-gate 401 on the authenticated export endpoint. The phase closed with a single phase-gate commit that auto-deployed through the Git integration, exactly as planned.

The Phase 5 and Phase 6 scope lines below are quoted from the owner-approved three-phase structure proposed at the end of the Phase 3 session: Phase 5 is intelligence (Vision-based lab report extraction with a review screen, the full LLM coach, and a trends engine), and Phase 6 is family and scale (caregiver dashboards, a doctor-visit PDF report, and CGM data import). Phase 4 deliberately builds the foundation those phases need while shipping none of their intelligence surface.



This inventory matters for two reasons. First, it proves that Phase 4 needs almost no new data entry surface: the tracking data the digest consumes already exists. Second, it shows the coach is already scaffolded as a route and page, so activating it is a configuration and wiring task rather than a greenfield build.

2.3 Current Data-Domain Inventory

The table below lists the data domains the application already manages, with the API route that owns them. This is the input surface for the Phase 4 digest feature; new Phase 4 API surface is limited to the aggregate digest endpoint and the lab panel endpoints specified in chapters 4 and 5. The full 21-route inventory with purposes is reproduced in Appendix A.

Domain	API route	Notes
Glucose	`/api/glucose`	Readings with fasting / post-prandial tags
Meals and combos	`/api/meals, /api/combos`	Meal logs and food-combination scores
Foods	`/api/foods, /api/foods/custom`	Indian food DB plus user-defined foods
Medications	`/api/meds, /api/meds/log`	Medication list and intake log
Lab results	`/api/labs`	Manual entry today; presets arrive in F2
Activity	`/api/activity`	Exercise and daily-activity entries
Sleep	`/api/sleep`	Sleep duration and quality
Blood pressure	`/api/bp`	Systolic / diastolic readings
Weight	`/api/weight`	Weight entries
Day tags	`/api/day-tags`	User-applied day labels
Reports and export	`/api/reports, /api/export`	Report rendering and JSON export
Coach (scaffold)	`/api/coach`	Inert until F3 activates the key

2.4 Known Issues and Phase 4 Preconditions

Three conditions carried out of Phase 3 shape Phase 4. First, the register-to-login defect: an account created through the register form is signed in automatically, but a subsequent credential login with the same email and password is rejected with the generic "Incorrect email or password" error, while pre-existing accounts such as demo@metabolic.dev log in normally. Root-cause evidence is being collected separately and the fix is committed with the Phase 3 gate commit; it is therefore a precondition, not a Phase 4 feature, and is referenced here as PR-P3. Smoke Test v2 in chapter 9 closes the blind spot this defect exposed by always exercising a fresh account through a full logout and credential re-login.

Second, the AI coach scaffold is inert: the build output contains a coach route lambda, but no OPENAI_API_KEY exists in the production environment, so the page cannot answer anything. F3 exists to

close exactly this gap. Third, account hygiene is thin: all six accounts share a demonstration password, there is no change-password flow, no reset flow, and per-user data isolation has never been verified systematically across all 21 routes. F4 closes all three sub-gaps within Phase 4, with email-based self-service reset explicitly deferred until an email provider decision is made.

3. Goals, Non-Goals and Success Metrics

3.1 Phase 4 Goal

Phase 4 turns the collected data into daily value and hardens the platform underneath it. The phase has one sentence of intent: every family member opens the dashboard and sees everything that matters about their day on one screen, can record a standard Indian lab panel in about a minute, can ask the AI coach one grounded question, and does all of it on accounts that are individually secure. That intent maps to four features: the consolidated daily-summary dashboard (F1), the lab entry upgrade with Indian diagnostic panel presets (F2), the AI coach activation (F3), and the account and data hygiene pack (F4). Each is specified in its own chapter with acceptance criteria that gate the release.

3.2 In Scope and Out of Scope

The table below is the binding scope contract for the phase. Items listed as deferred are not merely unprioritized; pulling any of them into Phase 4 requires the owner to explicitly swap it into the milestone table in chapter 10, and the swap must be recorded in the worklog. This mechanism exists because Phase 5 intelligence features (especially lab-photo OCR) are attractive and would otherwise creep into the foundation phase.

Feature / item	Phase	Rationale
F1 Daily-summary dashboard	Phase 4	Owner idea 1: consolidated daily digest
F2 Lab entry + Indian panel presets	Phase 4	Owner idea 2, manual entry portion
F3 AI coach activation	Phase 4	Existing scaffold; add key and grounding
F4 Account and data hygiene	Phase 4	Six real users; isolation never audited
Lab report photo OCR + review screen	Phase 5	Vision extraction needs cost and PII review
Full LLM coach memory and trends	Phase 5	Depends on F1 data and F3 activation
Caregiver dashboards, roles, invites	Phase 6	Needs role model beyond Phase 4 scope
Doctor-visit PDF report	Phase 6	Needs F2 lab data and report hardening
CGM and wearable import	Phase 6	External integrations; schema unknown
Email / SMS self-service reset, OTP	Phase 6	Needs provider selection; admin reset covers P4

3.3 Success Metrics

Phase 4 success is measured with the modest, verifiable numbers below. They are deliberately operation-flavored: the application has six users, so statistical product metrics are meaningless, but latency, entry time, and regression coverage are meaningful and cheap to verify. The build session should treat the target column as part of acceptance.

Metric	Target	Where verified
Digest first meaningful paint (p95)	Under 2.5 s on production	F1 acceptance, chapter 4
Basic lab panel entry time	60 s or less per panel	F2 acceptance, chapter 5
Coach answer latency (p95)	Under 8 s to first content	F3 acceptance, chapter 6
Coach daily cost ceiling	Owner-approved monthly cap	F3 FR-3.6, chapter 12 budget question
Cross-user data leakage	Zero routes leaking across users	F4 acceptance, chapter 7
Public probe suite	200 / 200 / 200 / 401 unchanged	Smoke Test v2, chapter 9
Fresh-account credential re-login	100% pass	Smoke Test v2 step 4, chapter 9

4. F1 - Consolidated Daily-Summary Dashboard (Digest v1)

4.1 Overview

The dashboard becomes a single "today at a glance" view assembled from data the application already stores. Digest v1 is an aggregation and presentation feature: it introduces no new tracking forms and expects no new user-entered data beyond what the existing pages collect. Its job is to answer, in one screen and under three seconds, the three questions the family actually asks: how am I doing today, what did I take and eat, and what needs my attention. Each summary card degrades independently, so a domain with no data shows an honest empty state with a link to the relevant logging page, never a broken or half-rendered card.

4.2 User Stories

The stories below are the acceptance narrative for the digest; the formal criteria follow in section 4.5. They are written from the perspective of the family members who use the app daily, including the owner's son, whose phone-only usage is the most common access pattern in the household.

- As a family member, I open the dashboard and see today's glucose summary, meals, medications taken and due, activity, sleep, blood pressure, weight, and my latest HbA1c without tapping anywhere else.

- As a family member, I pick a past date on the dashboard and the whole digest re-renders for that day, so I can answer "what did I do Tuesday" in one place.
- As the household admin, I see at a glance whether a lab result is overdue (no HbA1c in the last 90 days) so I stop chasing the family about tests.
- As a family member with a small phone screen, the digest loads fast enough on mobile data that I actually open it before breakfast.

4.3 Functional Requirements

The digest is served by one new endpoint and rendered as a card stack on /dashboard. Requirements are ordered; FR-1.1 through FR-1.4 form the core, the rest are quality rules that keep the feature pleasant at Phase 3's operational standard.

- FR-1.1 MUST: A new server endpoint GET /api/digest?date=YYYY-MM-DD returns one JSON block per card for the session user only, computed from existing tables; it MUST NOT accept or mutate data.
- FR-1.2 MUST: Default date is the user's current day in the user timezone (see FR-1.6); an explicit date parameter renders that day.
- FR-1.3 MUST: Cards: Glucose (latest reading, fasting average, post-prandial average, and a 90-day glucose management indicator computed as eAG and shown with both mmol/L and mg/dL labels when data exists); Meals (count and estimated carbohydrates today); Medications (scheduled items marked taken or due); Activity; Sleep; Blood pressure latest; Weight latest with 7-day delta; Labs (most recent HbA1c value and an overdue flag when older than 90 days).
- FR-1.4 MUST: Every card has a defined empty state naming the logging page that would fill it, linked.
- FR-1.5 MUST: Card computation is independent per domain; one failing or slow source MUST NOT blank other cards (server: fail-soft per block with a partial flag; client: per-card error state).
- FR-1.6 MUST: Day boundaries use the user timezone captured at onboarding, defaulting to Asia/Kolkata; serverless UTC timestamps are never compared to user-local dates without conversion.
- FR-1.7 SHOULD: The endpoint aggregates server-side with indexed per-user queries rather than N client fetches, and adds database indexes on (userId, date-like) columns where the migration policy of chapter 8 permits additive index creation.
- FR-1.8 SHOULD: The digest page is usable at 360 px viewport width with a single scroll column.

4.4 Data and API Impact

Digest v1 is read-only over the existing schema. The only schema-adjacent action allowed is additive index creation under the chapter 8 policy, plus (optionally) storing the user timezone string on the profile if onboarding does not already capture it. The response envelope is a JSON object keyed by card slug, each with status ("ok", "empty", "error"), value, and a small meta block (period, sample count, link). This shape is shared with F3, which uses the same digest payload as grounding context, which is the main reason the aggregate endpoint is server-side.

4.5 Acceptance Criteria

Each criterion below is executable as a manual check on production after the milestone 2 deploy. They verify the requirements above in the order they are numbered.

- AC-1.1 Given a user with records in every domain, When they open /dashboard, Then all eight cards render with that user's own data and no loading skeleton remains after first paint.
- AC-1.2 Given a brand-new account, When the dashboard loads, Then every card shows its empty state with a working link to the right logging page and no card shows an error.
- AC-1.3 Given a user with glucose records, When the glucose card renders, Then fasting and post-prandial averages use only readings tagged accordingly, and the 90-day indicator matches a hand computation from the raw data.
- AC-1.4 Given a date picker selection of a past day, When the digest reloads, Then every card reflects that exact user-local day.
- AC-1.5 Given a user whose latest HbA1c is older than 90 days, When the Labs card renders, Then an overdue flag is visible with the value and its recorded date.
- AC-1.6 Given /api/digest?date=..., When called without a session, Then the response is 401, and When called for another user's id or date span, Then no cross-user data appears (F4 probe covers this route too).
- AC-1.7 Given a simulated slow source (for the demo, throttle one domain), When the dashboard loads, Then the other cards still render; the slow card shows its own progress state.
- AC-1.8 Given production timing, When 10 digest loads are measured, Then p95 first meaningful paint is under 2.5 seconds.

4.6 Out of Scope

Trend charts, correlation analysis, weekly and monthly rollups, configurable card layout, push or email reminders, and any coach-authored text inside the digest are all excluded from Digest v1 and belong to the Phase 5 trends work. The digest card grid also does not replace the existing per-domain pages, which remain the logging surface; the dashboard purely summarizes and links. These exclusions keep milestone 2 inside a single aggregate endpoint, one page redesign, and additive index changes, which is the size of change that can be verified by the six-user household within a week of real usage.

5. F2 - Lab Entry Upgrade and Indian Diagnostic Panel Presets

5.1 Overview

Today lab results are typed one test at a time with no notion of the panels that Indian diagnostic labs actually sell, which makes entering a routine checkup slow and error-prone. F2 adds three region-aware panel presets (Basic, Advanced, Super Advanced) to the existing manual lab entry flow. Selecting a preset pre-populates the test list; HbA1c is required in every tier and the remaining tests are optional per the user's original concept. Every test carries a default Indian reference range, and when a lab report prints its own range the user can store that override on the result. Photo-based extraction of the same form is explicitly Phase 5; Phase 4 perfects the typed path the OCR will eventually fill.

5.2 Proposed Tier Contents

The panel contents below are a starting proposal drawn from common Indian diagnostic lab packages; the owner MUST confirm or adjust the test lists before milestone 1 ships, and chapter 12 tracks this as an open question. Reference ranges ship as seed data with units and typical adult ranges, are always editable per result via the override capture, and are display-only guidance rather than medical assertion.

Tier	Tests (HbA1c always required)	Typical use
Basic	HbA1c, fasting blood sugar, post-prandial blood sugar, total cholesterol, triglycerides, HDL, LDL, VLDL, urea, creatinine	Quarterly routine check
Advanced	Basic plus: SGPT, SGOT, total bilirubin, total protein, TSH, urine routine, vitamin D, vitamin B12	Half-yearly deeper panel
Super Advanced	Advanced plus: fasting insulin with HOMA-IR, ApoB, hs-CRP, CBC with differential, ESR	Annual metabolic workup

5.3 Functional Requirements

F2 modifies one existing flow (the /labs page and /api/labs route) and adds two read endpoints plus seed data. Nothing in the feature writes to another user's data, and no file upload of any kind is included.

- FR-2.1 MUST: The lab entry form offers a tier picker (none / Basic / Advanced / Super Advanced); picking a tier renders the tier test list with fields, units, and default reference ranges.
- FR-2.2 MUST: HbA1c is required to save any preset-based panel; the API rejects a panel payload without it with a field-level message.
- FR-2.3 MUST: Untouched optional tests are simply skipped; no null rows are stored for tests left empty.
- FR-2.4 MUST: Each result stores an optional lab-reported reference range override (low and high with unit) next to the value; flagging (low / normal / high) uses the override when present and the seeded

default otherwise.

- FR-2.5 MUST: Panel results save as one lab-set transaction with a shared date and the tier recorded, so the report and digest can group them.
- FR-2.6 MUST: Existing single-test entries and past data render unchanged; the migration is additive and backward compatible.
- FR-2.7 SHOULD: GET /api/labs/panels returns the tiers and their test definitions so the form stays server-driven.
- FR-2.8 SHOULD: Out-of-range values show a muted flag icon in the form at entry time, using the same rule as FR-2.4.

5.4 Data and API Impact

The migration is additive-only per chapter 8: new tables and nullable columns, no renames or drops. Seed data must be idempotent (upsert keyed by panel tier and test key) so repeated migrations and future tier adjustments are safe. The table below is the intended shape; the build session maps it onto the existing Prisma schema and naming conventions.

Model / column	Purpose
LabPanel (id, tier, name, region)	The three preset tiers; region defaults to IN
LabPanelTest (id, panelId, testKey, name, unit, refLow, refHigh, required)	Per-tier test definitions and seeded Indian ranges
LabSet (id, userId, date, panelTier)	One saved panel transaction per user and date
LabResult additions (setId, testKey, value, unit, refLowOverride, refHighOverride, flag)	Panel-aware results; existing manual rows remain valid with null set fields

5.5 Acceptance Criteria

These criteria are checked on production as the milestone 1 gate. They assume the PR-P3 login fix is already live, because a fresh family account is used to enter the demo panel.

- AC-2.1 Given the /labs entry form, When each tier is picked, Then the correct test list renders with units and ranges, matching the owner-confirmed contents.
- AC-2.2 Given a Basic panel with only HbA1c filled, When saved, Then the set stores one result with correct value, unit, and flag, and skipped tests store nothing.
- AC-2.3 Given a panel payload without HbA1c, When saved via the API, Then the save is rejected with a clear message and nothing is stored.
- AC-2.4 Given a lab report printing a different range, When the user enters the override and a high value, Then the stored flag is computed against the override, and the report shows the override range.

- AC-2.5 Given a user with a saved Basic set, When the report and the digest Labs card load, Then the panel groups by set with its tier and date.
- AC-2.6 Given pre-Phase-4 lab rows, When the labs page loads, Then they render exactly as before with no migration artifacts.
- AC-2.7 Given two users, When user A lists their lab sets, Then no result of user B appears (covered by the F4 isolation probe).
- AC-2.8 Given a practiced user, When timing a Basic panel entry, Then the full save completes in about 60 seconds.

5.6 Out of Scope

Photo or PDF upload and OCR extraction, doctor-facing report formatting, non-Indian region presets, historical import, and charting lab trends are all out of scope. The Phase 5 OCR feature will target this same form, so the build session should keep the entry payload shape stable and well-named rather than clever. No medical-decision logic (dosage advice, alerting thresholds beyond display flags) is included anywhere in F2; the seeded ranges are display guidance only and the UI says so in fine print on the form.

6. F3 - AI Coach Activation

6.1 Overview

The coach route and page already exist in the build output, but with no OPENAI_API_KEY in the production environment the page is inert. F3 activates the coach as a grounded assistant: it answers questions using the same digest payload F1 produces, so its answers reference the user's actual recent data instead of generic advice. Phase 4 ships the narrow version deliberately: one round of grounded question answering with hard degradation rules, cost caps, and safety copy. The rich coach (memory across sessions, proactive daily tips, photo logging) is Phase 5 and is excluded here.

6.2 Functional Requirements

The coach stays behind the existing authenticated route. The environment addition follows the add-only policy in chapter 8 and Appendix B; nothing else about the deployment changes.

- FR-3.1 MUST: Add OPENAI_API_KEY to the Vercel environment for the project (all of production and preview), added only, never committed to the repository; the key is read server-side only and never shipped to the client bundle.
- FR-3.2 MUST: The coach endpoint accepts a question plus the current digest payload as context, and answers grounded in that data (citing the numbers it uses); questions outside the user's data get honest "I only see your recent data" behavior rather than invention.
- FR-3.3 MUST: Degradation matrix: key absent, invalid, quota exceeded, or upstream 5xx results in a calm "AI coach is unavailable right now" banner on the page; the page itself MUST NOT 5xx and

MUST NOT show a raw provider error to the user.

- FR-3.4 MUST: Medical safety copy is static and non-negotiable: the coach never gives medication dosing instructions and always frames output as informational; the same disclaimer renders with every answer.
- FR-3.5 MUST: Each user is capped at a default of 20 coach questions per day (server-enforced counter in the database); the cap is configurable by environment variable.
- FR-3.6 SHOULD: Model selection defaults to a low-cost chat model and is configurable by environment variable; prompts log to the server without PII beyond the user id.
- FR-3.7 SHOULD: The coach page shows the remaining daily question count so the cap never surprises the user.

6.3 Degradation and Cost Posture

Two small tables summarize behavior the build session must implement literally. Degradation is total and silent-safe: an unconfigured coach looks like a feature with a polite notice, never a broken product. Cost is capped in two dimensions (per-user daily count, plus owner-selected model) so a runaway client cannot create a bill surprise.

Condition	Page behavior	HTTP
Key present, upstream healthy	Grounded answer rendered	200
Key absent or empty	Banner: AI coach not configured	200 with status field
Key invalid or quota exceeded	Banner: AI coach unavailable	200 with status field
Daily cap reached	Friendly cap message with reset time	200 with status field
Upstream 5xx or timeout	Banner: AI coach unavailable	200 with status field

6.4 Acceptance Criteria

The milestone 3 gate runs these on production, including one deliberate negative test of the degradation path (key removed in a preview deployment, never in production).

- AC-3.1 Given the key is configured, When a user asks "What were my average fasting sugars this week?", Then the answer quotes numbers that match the digest values for that user.
- AC-3.2 Given a second user, When they ask the same question, Then the answer reflects the second user's data (F4 probe includes the coach route).
- AC-3.3 Given the 21st question of the day, When asked, Then the cap message appears and no provider call is made (verified by the counter).
- AC-3.4 Given the key is absent in a preview environment, When the coach page loads, Then the page renders 200 with the banner and no raw provider error string appears anywhere in the response.

- AC-3.5 Given any answer, When rendered, Then the medical disclaimer is present and no dosing instruction is ever produced (spot-check three questions).
- AC-3.6 Given production timing, When five coach questions are asked, Then p95 time to first content is under 8 seconds.

6.5 Out of Scope

Conversation memory across sessions, streaming token display beyond what the page already does, proactive morning summaries or emails, photo-based food logging, and any model fine-tuning are excluded from Phase 4. The feature is intentionally a thin, safe, grounded loop around one endpoint; the Phase 5 coach builds on it rather than replacing it, so the request and response shape designed here should be treated as an internal contract and kept stable.

7. F4 - Account and Data Hygiene Pack

7.1 Overview

The platform now holds real data for six people, and Phase 3 showed the account layer is its weakest point: accounts were created with a shared demonstration password, there is no change-password flow, no reset flow, and per-user isolation has only been assumed rather than verified across all 21 API routes. F4 fixes the password lifecycle for the accounts that exist and turns isolation into an automated regression rather than a hope. The register-to-login defect itself is fixed under PR-P3 with the Phase 3 gate commit; F4 depends on that fix and adds the safety net beneath it.

7.2 Functional Requirements

F4 touches settings, admin, and the API layer; it deliberately avoids any email-provider dependency, because that decision is still open (chapter 12) and admin-assisted reset covers the family's actual need.

- FR-4.1 MUST: A change-password flow in settings: current password, new password, confirm; the new hash is produced with the same scheme as register; all other sessions are invalidated on success; the current session stays signed in.
- FR-4.2 MUST: New passwords enforce a minimum of 10 characters with at least one letter and one digit; the rule applies to change-password and admin reset; existing accounts are never force-reset inside Phase 4.
- FR-4.3 MUST: An admin-assisted reset: the admin page lists user accounts (email, created date, last sign-in) and can set a new password for a chosen account, subject to the same strength rule and an audit line in the worklog style of the family's operational records.
- FR-4.4 MUST: An automated two-user isolation probe: a script or test that provisions two throwaway users, creates records for each, and asserts that every authenticated API route either scopes results to the caller or refuses cross-access; the probe runs as part of the release gate and its output is pasted into the phase worklog.

- FR-4.5 MUST: The isolation probe covers all 21 routes in Appendix A plus every new Phase 4 route (digest, panels, coach).
- FR-4.6 SHOULD: Login keeps returning the generic "Incorrect email or password" for both wrong-password and unknown-email (anti-enumeration; current behavior retained by design).
- FR-4.7 SHOULD: The six demonstration accounts get individual passwords at the phase gate using FR-4.1 or FR-4.3, and the shared demo password is retired; the owner holds the new list outside the repository.

7.3 Acceptance Criteria

These run at the milestone 4 gate on production with two throwaway accounts, and they are the criteria that make the household's data actually private at the route level.

- AC-4.1 Given a signed-in user, When they change their password with the correct current password, Then the next login works only with the new password and other devices are signed out.
- AC-4.2 Given a wrong current password, When change is attempted, Then it is rejected with the generic message and the hash is unchanged.
- AC-4.3 Given the admin, When resetting a family account password, Then the account can log in with the new password immediately and the reset is recorded in the worklog.
- AC-4.4 Given the two probe users A and B with records each, When the probe runs, Then zero routes return A's data to B or vice versa, and the probe output shows 21+ routes checked, 0 leaks.
- AC-4.5 Given a fresh registration, When the user logs out and logs back in with the same credentials, Then login succeeds (the PR-P3 regression check, now permanent).
- AC-4.6 Given any new password attempt under 10 characters or without a digit, When submitted, Then it is rejected with a field-level message.

7.4 Out of Scope

Email-based self-service reset, SMS or email OTP login, multi-factor authentication, account deletion and export policies, and role-based portals (separate doctor or admin logins) are all deferred per the owner-approved phase structure; the admin-assisted reset in FR-4.3 is the explicit Phase 4 substitute for the reset flow. Audit logging is worklog-level, not a database audit table. These exclusions keep F4 inside one settings page, one admin action, and one test script, which is verifiable in a single session.

8. Cross-Cutting Engineering Requirements

8.1 Migration Policy (Prisma on Turso)

All Phase 4 schema changes are additive-only: new tables and nullable columns are allowed; renames, drops, type changes, and destructive backfills are forbidden. Every migration is first rehearsed against a Turso branch database created from production, and the production migration runs only after the branch rehearsal passes with seeded production-like data. The build session records each migration name and the rehearsal result in the phase worklog. This policy exists because the single production database backs the live family deployment; there is no staging system, so the branch database is the staging system.

8.2 Environment Policy

The environment store follows the add-only policy proven in Phase 3: existing variables are never modified or deleted, and new variables are added only when a feature requires them. Phase 4 adds exactly one variable, OPENAI_API_KEY. The known sensitive-masking failure mode (a build failing with URL_INVALID or libsql errors after a variable type change, tracked upstream as vercel/vercel#17514) remains the standing contingency: if that signature appears, correct the variable type rather than the code, and only for the affected variable. Local secret files (.env.turso, .env.production, .env.local) are gitignored via the .env* rules verified at the Phase 3 gate and must never be committed or pasted anywhere.

Variable	Status	Phase 4 action
DATABASE_URL	Existing (Sensitive)	None - never touch
DATABASE_AUTH_TOKEN	Existing (Sensitive)	None - never touch
NEXTAUTH_SECRET	Existing (Sensitive)	None - never touch
NEXTAUTH_URL	Existing (Sensitive)	None - value is the canonical URL
OPENAI_API_KEY	New	Add for F3 (Production and Preview); Sensitive
COACH_DAILY_CAP (optional)	New	Add only if FR-3.5 default 20 is not enough
VERCEL_OIDC_TOKEN	Never	Never add as a project variable

8.3 Deployment and Verification Pipeline

The only sanctioned production deploy is the pipeline Phase 3 proved: a cloud build from the repository root with vercel deploy --prod --yes, whose upload mirrors the repository so the Git-configured root directory (apps/web) resolves. The prebuilt pipeline (vercel build plus deploy --prebuilt) is banned permanently; it produced empty, 404-on-every-path artifacts during the stray-project episode. Pushing to the linked Git branch auto-deploys production, which is expected and is how phase-gate commits ship. After every production deploy, the four-URL public probe suite must pass unchanged (200 on /, /login, /api/auth/csrf, and a bare 401 on /api/export?format=json with no Location header); any 302 means Vercel Deployment Protection intervened and must be fixed in the dashboard before the deploy counts as shipped. Any server error during smoke testing triggers vercel logs and vercel env ls production before any code changes.

9. QA Plan and Release Gates

9.1 Smoke Test v2

Smoke Test v2 replaces the Phase 3 script and runs on production at every milestone gate. Its defining change is step 4: every fresh account must survive a full logout and credential re-login, the exact path the register-to-login defect broke. The steps below are executed in order; any failure stops the gate and is triaged with vercel logs before anything else.

Step	Check	Pass condition
1	Public probe suite (4 URLs)	200 / 200 / 200 / 401, no Location header
2	Register a fresh throwaway account	Auto-login lands on dashboard
3	Log out	Session cleared, /login reachable
4	Credential re-login with the same password	Login succeeds (PR-P3 regression)
5	Food + glucose + meds + activity + sleep records	Each saves and lists
6	Basic lab panel entry	Saves as one set; flags correct (AC-2.2)
7	Dashboard digest for today	All cards reflect steps 5-6 (AC-1.1)
8	Coach grounded question	Answer cites real numbers (AC-3.1)
9	Reports page	Renders with the created records
10	JSON export	200; body contains every created record
11	Two-user isolation probe	0 leaks across 21+ routes (AC-4.4)
12	Change password; old password retry	New works, old rejected (AC-4.1)

9.2 Release Gate Checklist

A Phase 4 milestone is done when its feature-specific acceptance criteria pass on production, the full Smoke Test v2 passes, and the bookkeeping below is complete. The pattern deliberately mirrors the Phase 3 gate that worked: a guarded append to the phase worklog (docs/phase4-worklog.md, created at milestone 1 with a marker-existence check like the Phase 3 one), confirmation that .vercel and .env* stay gitignored, a single milestone commit whose push auto-deploys through the Git link, and no manual edits to the Vercel dashboard except the protection setting that the probe suite legitimately flagged.

- All acceptance criteria for the milestone features pass on production (chapters 4-7).
- Smoke Test v2 passes end to end, including step 4.
- Migration rehearsal result recorded; production migration applied with zero data loss.
- Guarded worklog append for the milestone (marker check then append only).
- .vercel and .env* still gitignored; git status clean of secrets before the commit.
- Single milestone commit; push auto-deploys; probe suite re-run green on the new deployment.

10. Milestones and Sequencing

Phase 4 is delivered in four milestones, each ending in a production gate demo rather than a code review artifact. The order below reflects real dependencies: the migration machinery and the isolation probe come first because every later milestone writes new routes that the probe must cover; the digest depends on lab data shaped by the panel work only loosely, so the two can swap if the owner prefers seeing the dashboard first; the coach is last among features because it consumes the digest payload as its grounding contract.

Milestone	Contents	Gate demo on production
M1 - Lab foundation	F2 panels, seed data, additive migration rehearsal on a branch DB, isolation probe harness (F4 FR-4.4)	Basic panel entered in about a minute; probe output pasted
M2 - Digest	F1 aggregate endpoint, dashboard card stack, timezone handling, additive indexes	Today-at-a-glance with real family data for two users
M3 - Coach	F3 key addition, grounded endpoint, caps, degradation banners	Grounded answer quoting real numbers; cap message shown
M4 - Hygiene and release	F4 change password, admin reset, isolation audit across all routes, demo password rotation, worklog and phase commit	Full Smoke Test v2 green; 0 isolation leaks; passwords rotated

The whole phase is sized for one focused build session with the owner verifying gates between milestones. If schedule pressure forces a cut, the cut order is: drop the Super Advanced tier content first (ship Basic and Advanced), then the weight and activity cards, then the coach follow-ups; the isolation probe, the

re-login regression, and the digest itself are never cut, because they are the phase's actual safety and value core.

11. Risks and Mitigations

The register-to-login defect is the only phase risk with an unknown root cause at the time of writing; evidence collection is in flight in the deployment session and the fix rides the Phase 3 gate commit. Every other risk below is a known shape with a standing mitigation the build session should treat as part of the plan, not as optional advice.

Risk	Impact	Mitigation
Login bug root cause slips past the Phase 3 gate	All Phase 4 gates block on step 4	PR-P3 precondition; fresh-account re-login runs in every gate
OPENAI key leakage or runaway cost	Bill surprise; security exposure	Server-only key; per-user daily cap; low-cost default model; owner sets a monthly provider alert at key creation
Production migration goes wrong	Family data loss or downtime	Additive-only policy; branch-DB rehearsal; no destructive change in Phase 4, period
Indian reference ranges vary by lab and person	Misleading flags erode trust	Range override capture on every result (FR-2.4); owner confirms tier contents; flags are display-only guidance
Phase 5 scope creep (OCR, trends) pulls into Phase 4	Foundation phase balloons; quality drops	Chapter 3 non-goals table is binding; swaps require owner sign-off in the worklog
Single maintainer with full credentials	Bus-factor and account-recovery fragility	Worklog discipline; passwords rotated off the shared demo value; owner holds the account list; admin reset path exists (FR-4.3)

12. Open Questions

These are the decisions the owner owns. None of them blocks milestone 1, but each has a default noted that the build session should follow until the owner answers otherwise. Answers should be recorded in the phase worklog next to the question number so the defaults and decisions stay distinguishable in the future.

#	Question	Working default
Q1	Exact test lists for the three lab tiers	The chapter 5 proposal; owner adjusts before M1
Q2	Email provider for future self-service reset	None in Phase 4; admin reset substitutes
Q3	Coach model choice and monthly budget	Low-cost chat model; 20 questions per user per day
Q4	Demo account password policy at the gate	Individual passwords; shared demo1234 retired (FR-4.7)
Q5	Per-user timezone vs global IST	Per-user profile field defaulting to Asia/Kolkata (FR-1.6)
Q6	Glucose indicator naming for lay users	Show eAG value labeled "estimated average glucose (GMI)"
Q7	Indian food database expansion in Phase 4	No expansion; /indian and custom foods are unchanged
Q8	Coach daily cap value	20 per user per day, environment-overridable (FR-3.5)

Appendix A - Current API Inventory

The 21 API routes below exist at the Phase 3 gate commit under apps/web/src/app/api. This inventory is the F4 isolation probe checklist and the baseline the digest and panel endpoints join. Purposes are one-line operational summaries, not full contracts; the route source files remain authoritative.

Route	Purpose
`/api/activity`	Activity and exercise entries
`/api/auth/[...nextauth]`	NextAuth credential auth endpoints
`/api/bp`	Blood pressure readings
`/api/coach`	AI coach scaffold (inert until F3)
`/api/combos`	Food combination scores
`/api/day-tags`	User-applied day labels
`/api/export`	Authenticated data export (JSON)
`/api/foods`	Food database queries
`/api/foods/custom`	User-defined foods
`/api/glucose`	Glucose readings with fasting / PP tags

Route	Purpose
`/api/labs`	Lab results (manual entry today)
`/api/me/profile`	Own profile read and update
`/api/meals`	Meal logs
`/api/meds`	Medication list
`/api/meds/log`	Medication intake log
`/api/onboarding`	First-run profile capture
`/api/reports`	Report data assembly
`/api/settings`	User settings
`/api/signup`	Account registration
`/api/sleep`	Sleep entries
`/api/weight`	Weight entries

Appendix B - Production Environment Policy

This appendix restates the environment rules proven during the Phase 3 pivot so a build session never has to reverse-engineer them. The store is managed with an add-only discipline: verification begins with vercel env ls production, missing variables are added, and nothing pre-existing is ever edited or removed. Values for database variables come only from the local .env.turso file as plain values when an addition is ever needed; values from .env.production are never used, because that file holds a local file: development URL and copying it upstream would point production at a dev database. The five current production variables and their status are listed in the chapter 8 table; OPENAI_API_KEY is the only addition Phase 4 makes.

Two standing contingencies complete the policy. First, the build-failure signature URL_INVALID or libsql connection errors after touching environment variables indicates the sensitive-value masking issue tracked as vercel/vercel#17514; the remedy is correcting the variable type for the affected key only, never a code change and never a bulk re-add. Second, deployment protection: the four-URL probe suite treats any 302 redirect to vercel.com/sso-api as a hard failure meaning protection was enabled at the account level; the owner changes that setting in the Vercel dashboard (Standard Protection or Disabled) and the probe is re-run before the deploy is accepted. Both contingencies were exercised successfully during the Phase 3 pivot, and this appendix exists so their playbook survives into Phase 4 and beyond.